IDENTITY & ACCESS MANAGEMENT

JANUARY 11, 2026

# HIPAA Compliance Checklist: Steps to Stay Audit-Ready in 2026

Aditya Santhanam

Founder and CTO, Infisign

Talk with Expert

A HIPAA audit usually doesn't kick off with a breach. Instead, it often starts with a

straightforward request: show us your risk



breaches or even were heavy fines from the Department of Health and Human Services (One such case being Warby Parker being fined 1.5 Million USD in 2025!) .

To prevent this and meet HIPAA compliance requirements, organizations must protect health information through clear safeguards, documented processes, and ongoing oversight. A HIPAA Compliance Checklist helps turn these expectations into repeatable actions teams can follow before an audit request arrives.

This HIPAA Compliance Checklist breaks compliance into clear, audit-ready steps for 2026.

You'll find this step-by-step checklist, one to spot common gaps, trigger findings, and guidance on using automation and identity controls to reduce compliance risk.

## What Changes in HIPAA Enforcement and Security Expectations in 2026?

These days, HIPAA enforcement is all about proof. Auditors are looking for solid evidence that security controls are effective right now, not just policies from years ago.

Table of Contents

What Changes in HIPAA Enforcement and Security Expectations in 2026?

HIPAA Compliance Checklist (Step-by-Step Guide for 2026)

Who Must Follow the HIPAA Compliance

incident response.

The Office for Civil Rights (OCR) audits are already checking to see if safeguards align with actual system behavior, rather than just what's written down. One-off risk assessments and planned fixes won't cut it anymore. Teams need to demonstrate ongoing reviews, documented fixes, and tested response plans to be audit-ready in 2026.

# HIPAA Compliance Checklist (Step-by-Step Guide for 2026)

The HIPAA compliance checklist lays out required compliance in clear, actionable steps for 2026. It mirrors the actual audit process, from defining your role to providing evidence when asked. Each step details what to implement, document, and what auditors will be looking for. Use it to spot gaps, assign responsibilities, and keep your controls up to date as systems, vendors, and risks evolve.

## Step 1: Confirm Your HIPAA Role and Scope

Start by determining how your organization actually interacts with protected health information

And IAM Reduce HIPAA Compliance Risk

About Infisign

Infisign is a modern Identity & Access Management platform that secures every app your employees and partners use.

Zero-Trust Architecture

Trusted by Fortune 500 Companies

SOC 2 Type II Certified

Fast Migration from Any IAM

6000+ App Integrations

Save up to 60% on IAM Costs

(PHI). HIPAA applies based on real data access.

See Infisign in

Platform Products Why Infisign Pricing Resources Integrations EN Get a Free Trial

To complete this step, you should:

- Identify whether you deliver care, pay for care, or support those activities using PHI
- List all services, systems, and workflows that create, store, or transmit PHI or ePHI
- Review vendor and client relationships where PHI is involved
- Confirm your role for each use case using HHS definitions
- Document these decisions and revisit them whenever services, systems, or vendors change

This scope decision sets the foundation for every control that follows.

## Step 2: Appoint a Privacy Officer and Security Officer

HIPAA expects clear ownership for privacy and security decisions. This step is about assigning responsibility, not just titles. **A Privacy Officer** oversees how PHI is used and disclosed. **A Security Officer** is responsible for protecting electronic PHI. One person can handle both roles, but the duties must be explicit and backed by authority. **Auditors** focus on whether someone is accountable when issues arise, approvals are needed, or incidents occur.

**To complete this step, you should:**



- Document reporting lines and escalation paths
- Share contact details internally and, where required, externally
- Review role assignments when staffing or structure changes

Clear ownership keeps controls active and defensible during audits.

## Step 3: Map ePHI Data, Systems, and Access Points

This step focuses on getting a clear view of where electronic PHI exists and how it moves across your environment. That includes applications, databases, endpoints, cloud platforms, backups, and any data shared with vendors. The goal is accuracy. The map should reflect how data actually flows today, including remote access and third-party connections.

**To complete this step, you should:**

- List all systems and applications that store, process, or transmit ePHI
- Identify where ePHI enters, moves between, and leaves your environment
- Document vendors and integrations involved in data sharing

Record who can access ePHI, how they



assessment and control decisions.

## Step 4: Conduct and Document a HIPAA Security Risk Assessment

This step requires a formal review of how well your current controls protect ePHI across systems, users, and vendors. The assessment should identify where threats exist, how likely they are to occur, and what impact they would have. HIPAA expects this analysis to reflect your current environment, not past states. A one-time assessment does not meet the requirement.

**To complete this step, you should:**

- Evaluate every system, application, and vendor that handles ePHI
- Identify security risks, vulnerabilities, and potential impact
- Document mitigation actions with owners and timelines
- Track progress on remediation efforts
- Revisit the assessment after system changes, vendor updates, or incidents

A current, documented risk assessment anchors every safeguard that follows.

## Step 5: Create a Written HIPAA



how your organization meets HIPAA requirements in day-to-day operations, not just on paper. It brings together policies, safeguards, risk assessment findings, and remediation actions, with clear ownership and review timelines.

**To complete this step, you should:**

- Document required safeguards under the Privacy and Security Rules
- Tie each policy and control to a named owner
- Define review cycles and update schedules
- Link remediation actions to your latest risk assessment
- Keep the plan current as systems, vendors, or risks change

A written plan gives auditors a clear view of accountability and ongoing oversight.

## Step 6: Implement and Maintain Administrative Safeguards

Administrative safeguards cover how HIPAA compliance operates in practice. This includes enforcing policies, managing workforce access, overseeing vendors, and tracking risk remediation. These controls only work if they are actively maintained. HIPAA expects administrative

safeguards to reflect current operations, staffing



- Review user roles and access assignments on a set schedule
- Track remediation actions from risk assessments
- Monitor vendor compliance and internal enforcement
- Update safeguards when processes, systems, or staffing change

Consistent execution shows auditors that compliance is managed, not assumed.

## Step 7: Implement Technical Safeguards for ePHI

Technical safeguards are central to HIPAA IT compliance. They determine who can access ePHI, how access is authenticated, and what activity is recorded. Strong access control for HIPAA includes role-based access, encryption, and continuous monitoring across on-prem and cloud environments. HIPAA does not prescribe tools, but it does require controls that reflect how your systems are actually used, including remote access and third-party integrations.

**To complete this step, you should:**

Assign unique user IDs and apply role-based



- Encrypt ePHI in storage and during transmission
- Secure remote, mobile, and cloud access paths

Strong technical controls reduce breach risk and stand up to audit testing.

## Step 8: Implement Physical Safeguards for Facilities and Devices

Physical safeguards focus on how people and devices access ePHI in real-world settings. This includes offices, remote workspaces, laptops, mobile devices, servers, and storage media. Controls should reflect where work actually happens today, not just formal office environments. Auditors expect physical protections to align with your operational reality.

**To complete this step, you should:**

- Restrict access to offices, server rooms, and secure areas
- Lock down workstations and enable screen protections
- Track devices that store or access ePHI
- Secure, wipe, and dispose of devices and media properly

Define and enforce remote and mobile device



## Associates and Close BAA Gaps

This step focuses on understanding who outside your organization can access PHI. Business associates include any vendor or partner that creates, receives, maintains, or transmits PHI on your behalf. Common examples include cloud providers, billing services, IT support, consultants, and analytics vendors. Each relationship must be governed by a valid Business Associate Agreement (BAA).

**To complete this step, you should:**

- Create a complete inventory of vendors that handle PHI or ePHI
- Match each vendor to an active, role-appropriate BAA
- Identify agreements that are missing, outdated, or too generic
- Update BAAs when services, data access, or vendors change
- Periodically review vendor security and compliance practices

Clear vendor oversight reduces downstream audit and breach risk.

## Step 10: Enforce Workforce Training



incident reporting, with content tailored to job roles and access levels. One-time onboarding sessions are not enough. Training must stay current as systems, risks, and workflows change.

**To complete this step, you should:**

- Train employees when they join and on a recurring schedule
- Adjust training content based on role and data access
- Track training completion and maintain records
- Reinforce how and when to report security or privacy incidents
- Update training after policy or system changes

Consistent awareness reduces human error and audit exposure.

## Step 11: Operationalize Privacy Rule Requirements

This step focuses on making patient rights processes work in practice. The HIPAA Privacy Rule governs how PHI is used, disclosed, and accessed, including patient requests for access, amendments, and disclosure records. Compliance

depends on having clear workflows that staff follow.



amendments, and disclosures
- Verify requester identity and document decisions
- Track timelines and outcomes for each request
- Apply minimum necessary rules consistently
- Review requests periodically for accuracy and consistency

Operational processes reduce complaints and audit findings.

## Step 12: Test Incident and Breach Response Procedures

This step ensures your organization can detect, respond to, and document security events involving PHI. Written response plans are required, but regulators also expect evidence that teams know how to execute them. This includes handling security incidents that may not qualify as reportable breaches.

**To complete this step, you should:**

- Define clear incident and breach response workflows
- Assign response roles and escalation paths

Test response plans through tabletop or



Testing reveals gaps before an audit or breach does.

## Step 13: Maintain an Audit-Ready Evidence Pack

This step focuses on how quickly and confidently you can respond to an audit request. An audit-ready evidence pack is a centralized collection of documents that show how HIPAA requirements are met in practice. It should include policies, risk assessments, training records, BAAs, incident logs, and access reviews, all kept current and easy to retrieve.

**To complete this step, you should:**

- Store compliance documents in a single, secure location
- Assign ownership for each document type
- Use consistent naming and version control
- Update evidence on a defined schedule
- Retain records for at least six years

Organized evidence reduces audit delays and scrutiny.

## Step 14: Continuously Monitor, Review, and Improve Controls

This step ensures HIPAA controls stay effective as



weakens when reviews happen only during audits.

**To complete this step, you should:**

- Review access permissions and activity logs on a set schedule
- Reassess risks after system updates, vendor changes, or incidents
- Track control gaps and remediation efforts
- Test safeguards periodically and document improvements
- Update controls based on findings

Ongoing review keeps compliance defensible year-round and aligns your program with HIPAA compliance best practices as systems, users, and risks evolve.

# Who Must Follow the HIPAA Compliance Checklist?

This HIPAA Compliance Checklist applies to organizations based on how they interact with health data, not their size, industry, or internal titles. Any organization that creates, receives, maintains, or transmits protected health information (PHI) must assess its role under HIPAA and follow the appropriate requirements.

**Covered entities** include healthcare providers



complying with the Privacy, Security, and Breach Notification Rules.

**Business associates** are vendors or partners that handle PHI on behalf of covered entities. This group often includes cloud service providers, billing and coding services, IT support firms, analytics vendors, and consultants. Subcontractors of business associates are also covered when they access PHI.

**Why it matters:** HIPAA obligations follow data access. When services, systems, or vendors change, compliance scope can change too. Regular review prevents hidden audit risk.

# Top HIPAA Compliance Gaps That Trigger Audit Findings

Audits often fail on basics that a HIPAA compliance checklist is designed to catch early. These gaps show up repeatedly across enforcement actions and desk audits.

| Compliance Gap |
| --- |
| Outdated risk assessments |

HIPAA requires risk analysis to reflect current operations

**Compliance Gap**
Weak access controls

**What Auditors See**
Shared accounts, excessive permissions, or no access reviews

**Why It Triggers Findings**
Auditors expect least-privilege access and regular reviews

**Compliance Gap**
Missing or outdated BAAs

**What Auditors See**
Vendors handle PHI without valid agreements

**Why It Triggers Findings**
BAAs are mandatory for all PHI-sharing relationships

**Why It Triggers Findings**

Audits test real behavior, not documented intent

**Compliance Gap**

Incomplete training records

**What Auditors See**

Training occurred, but attendance or role-based content is missing

**Why It Triggers Findings**

Organizations must prove workforce awareness

**Compliance Gap**

Untested incident response

**What Auditors See**

Plans exist, but no testing or documented outcomes

# How Automation And IAM Reduce HIPAA Compliance Risk

HIPAA non compliance is something worth taking seriously as it affects your reputation as a brand and comes with settlements that easily go into hundreds of thousands of dollars.

This can even be for something that's more of an oversight than negligence like in the case of Heritage Valley Health System settlement that cost them over $950,000.

And unfortunately, manual user provisioning, delayed deprovisioning, shared credentials, and weak audit trails make it hard to prove who accessed ePHI and why.

Automation and identity access management (IAM) reduce this risk by enforcing access rules consistently and creating clear evidence for audits.

Infisign addresses these challenges through an AI-driven IAM platform that **centralizes identity governance, access controls, and audit visibility** across cloud and on-prem systems. It helps organizations reduce human error, and stay

audit-ready without relying on fragmented tools or



and deprovisioning across applications as employees join, change roles, or leave. Ensure access updates happen in near real time, reducing manual delays and preventing former users from retaining access to systems.

- **PAM with Least Privilege Enforcement**: Control privileged access through session-based elevation and policy-driven approvals. Infisign PAM grants elevated access only when required and monitors sessions to limit exposure of sensitive systems and administrative functions.
- **Passwordless Authentication**: Infisign passwordless authentication replaces passwords with phishing-resistant methods like biometrics (fingerprint/face) or device-bound cryptographic keys that authenticate without shared secrets. This eliminates the risk of credential theft while maintaining secure access to clinical and admin systems.
- **Multi-Factor Authentication (MFA) and Secure Sign-On Controls**: Apply Infisign Adaptive MFA dynamically based on contextual risk signals such as device trust, location, and user behavior. Strengthen authentication during high-risk access

without adding friction to routine, low-risk



responsibilities and least-privilege expectations.

- **Detailed Logging and Audit Trails**: Record identity activity, authentication events, and privileged access sessions in detailed logs. Support audit requests and investigations without manual reconstruction of access history.
- **Policy Enforcement and Compliance Automation**: Apply access policies consistently across applications using identity context and risk conditions. Update enforcement automatically as users, roles, or environments change to reduce human error.
- **Identity Governance and Administration**: Manage roles, entitlements, and access decisions from a single platform. Maintain continuous visibility into who can access systems as user populations evolve.

If access management keeps appearing as a gap in your HIPAA Compliance Checklist, it may be time to evaluate how Infisign supports identity-driven compliance. Get a demo today!

## FAQs

### What are HIPAA compliance requirements?

HIPAA compliance requires organizations to



responding to incidents. Compliance depends on how PHI is accessed, used, stored, and shared.

## What are the three major rules in HIPAA regulations?

The three major HIPAA rules are the Privacy Rule, Security Rule, and Breach Notification Rule. The Privacy Rule governs PHI use and patient rights. The Security Rule focuses on protecting electronic PHI. The Breach Notification Rule defines when and how breaches must be reported.

## What is the difference between HIPAA and GDPR?

HIPAA protects health information in the United States and applies to specific healthcare-related entities. GDPR protects personal data of EU residents across industries. GDPR grants broader individual rights and applies regardless of sector, while HIPAA focuses narrowly on healthcare data handling.

## Who must comply with HIPAA?

HIPAA applies to covered entities and business associates. Covered entities include healthcare providers, health plans, and clearinghouses. Business associates are vendors that handle PHI on their behalf. If your organization accesses PHI, HIPAA compliance likely applies.

Aditya Santhanam
Founder and CTO, Infisign

Aditya is a seasoned technology visionary and the founder and CTO of Infisign. With a deep passion for cybersecurity and identity management, he has spearheaded the development of innovative solutions to address the evolving digital landscape. Aditya's expertise in building robust and scalable platforms has been instrumental in Infisign's success.

Download



## Products

Infisign IAM Suite

UniFed

Infisign SSO

MFA Solution

PAM Solution

## Company

About Us

## Resources

Blog

Competitor Reviews

Webinars

Case Studies

+1 (862) 386 8165

22 Henry Road, Branchburg, NJ 08876

demos@infisign.io

## Competitors

Infisign vs Okta

Infisign vs Lastpass

Infisign vs Red Hat

Infisign vs Azure AD

Infisign vs Cyberark

© 2025 by Infisign. All rights reserved.